

LAPORAN TEKNIS PROYEK

KOM1315 – Keamanan Informasi

Implementasi Protokol Keamanan dan Kriptografi pada Sistem E-Commerce Jatibahagya

**Disusun Oleh:
Kelompok 6**

1.	Taura Mohamad Inzaghi	G6401231019
2.	Muhammad Syafiq Romadhon	G6401231079
3.	Muhammad Fauzan Akbar	G6401231045

Program Studi Ilmu Komputer
Sekolah Sains Data, Matematika, dan Informatika
IPB University
Bogor, Juni 2026

Repositori: github.com/Akbar3776/KOM1315_SmtGenap26_Kelompok6_E-CommerceJatibahagya

KATA PENGANTAR

Puji dan syukur kami panjatkan ke hadirat Allah SWT atas limpahan rahmat dan karunia-Nya, sehingga Laporan Teknis Proyek untuk mata kuliah KOM1315 Keamanan Informasi ini dapat diselesaikan. Laporan ini merupakan dokumentasi komprehensif dari seluruh rangkaian pengerjaan proyek pengembangan sistem e-commerce Jatibahagya, mulai dari tahap analisis kebutuhan, perancangan arsitektur keamanan, implementasi kode sumber, hingga pengujian akhir sistem.

Sistem yang dikembangkan dalam proyek ini, Jatibahagya WebApp, merupakan platform e-commerce berbasis web yang dibangun untuk menjawab tantangan transformasi digital yang dihadapi oleh perusahaan furnitur Jatibahagya. Fokus utama proyek ini bukan sekadar membangun aplikasi jual beli online biasa, melainkan memastikan seluruh komponen sistem dilindungi oleh lapisan keamanan informasi yang solid—mulai dari enkripsi data autentikasi hingga pengamanan jalur komunikasi secara real-time.

Laporan ini disusun sebagai dokumen kompilasi yang mencakup empat bagian utama: Proposal Proyek, Dokumen Desain Sistem dan Keamanan, Manual Penggunaan Fitur Keamanan bagi Administrator, dan Log Pengujian Sistem. Keempat bagian disajikan secara terintegrasi agar pembaca dapat memahami alur berpikir dan proses pengambilan keputusan teknis selama proyek berlangsung.

Kami menyadari bahwa laporan ini masih memiliki keterbatasan, dan segala kritik serta saran yang membangun sangat kami harapkan untuk perbaikan di masa mendatang.

Bogor, Juni 2026

Kelompok 6 – KOM1315 Keamanan Informasi

DAFTAR ISI

Kata Pengantar	i
Daftar Isi	ii
Daftar Tabel	iii
BAB 1 Pendahuluan	1
1.1 Latar Belakang	1
1.2 Tujuan Proyek	3
1.3 Ruang Lingkup Proyek	4
1.4 Manfaat Proyek	4
BAB 2 Tinjauan Pustaka	5
2.1 E-Commerce dan Tantangan Keamanan Informasi di Indonesia	5
2.2 Kriptografi Simetris: Algoritma AES	6
2.3 Hashing Password dengan Bcrypt	7
2.4 One-Time Password (OTP)	8
2.5 Kerangka Keamanan AAA	9
2.6 Role-Based Access Control (RBAC)	10
2.7 Framework Laravel dan Filament 3	11
2.8 Komunikasi Real-Time Berbasis WebSocket	12
BAB 3 Proposal Proyek	13
3.1 Latar Belakang Teknis	13
3.2 Identifikasi Masalah	14
3.3 Tujuan dan Target Luaran	15
BAB 4 Desain Sistem dan Keamanan	16
4.1 Arsitektur Sistem	16
4.2 Analisis Ancaman (Threat Modeling)	17
4.3 Desain Basis Data	19
4.4 Protokol Keamanan yang Diimplementasikan	20
4.5 Alur Kerja Sistem Secara Keseluruhan	25
BAB 5 Manual Penggunaan Fitur Keamanan bagi Administrator	26
5.1 Akses Modul Administrasi (Filament)	26
5.2 Manajemen Pengguna dan Peran (RBAC)	27
5.3 Prosedur Autentikasi dan Pengelolaan OTP	28
5.4 Pemantauan Log Transaksi dan Komunikasi Aman	29
5.5 Panduan Keamanan Operasional	30
BAB 6 Log Pengujian Sistem	32
6.1 Lingkungan Pengujian	32

6.2 Skenario Pengujian Fungsional dan Keamanan	33
6.3 Pengujian Performa: Plaintext vs Enkripsi AES	37
6.4 Analisis Hasil Pengujian	39
BAB 7 Penutup	41
7.1 Kesimpulan	41
7.2 Saran Pengembangan	43
Daftar Pustaka	44

DAFTAR TABEL

Tabel 1 Perbandingan mekanisme keamanan yang diimplementasikan dan mitigasi ancaman.	18
Tabel 2 Matriks hak akses RBAC berdasarkan peran pengguna.	23
Tabel 3 Ringkasan skenario pengujian fungsional dan keamanan sistem Jatibahagya WebApp.	34
Tabel 4 Perbandingan waktu rata-rata pemrosesan: plaintext vs enkripsi AES.	38
Tabel 5 Analisis overhead enkripsi dan implikasinya terhadap pengalaman pengguna real-time.	39

BAB 1 PENDAHULUAN

1.1 Latar Belakang

Perkembangan teknologi informasi dan komunikasi digital membawa perubahan mendasar dalam pola aktivitas bisnis di Indonesia. Berdasarkan publikasi Statistik E-Commerce 2023 yang diterbitkan oleh Badan Pusat Statistik (BPS 2025), jumlah usaha yang menjalankan aktivitas perdagangan melalui internet di Indonesia terus meningkat secara konsisten dari tahun ke tahun. Fenomena ini mencerminkan betapa cepatnya adopsi platform digital, termasuk oleh pelaku usaha kecil dan menengah (UMKM) di berbagai sektor industri.

Jatibahagya merupakan perusahaan yang bergerak di bidang produksi dan distribusi furnitur berbahan baku kayu jati berkualitas tinggi. Sebelum proyek ini dimulai, seluruh proses bisnis perusahaan—mulai dari penerimaan pesanan, pencatatan inventaris, hingga komunikasi dengan pelanggan—masih dilakukan secara manual dan tidak terintegrasi. Ketergantungan pada sistem manual ini mengakibatkan sejumlah masalah operasional nyata: data pelanggan tersebar di berbagai catatan yang rentan hilang, proses pemrosesan pesanan berjalan lambat karena tidak ada sistem terpusat, dan jangkauan pemasaran sangat terbatas pada area lokal.

Menjawab tantangan tersebut, proyek ini mengembangkan Jatibahagya WebApp, sebuah platform e-commerce berbasis web yang komprehensif. Platform ini tidak sekadar berfungsi sebagai etalase produk digital, melainkan sebagai sistem bisnis terintegrasi yang mendukung manajemen katalog, pemrosesan pesanan, pengelolaan inventaris, dan fasilitas komunikasi real-time antara pelanggan dan staf customer support.

Namun, pembangunan sebuah platform e-commerce tanpa fondasi keamanan yang kuat justru dapat menjadi sumber masalah yang jauh lebih besar. Dalam era digital ini, setiap sistem yang terhubung ke internet berpotensi menjadi target serangan siber. Husain et al. (2024) dalam Jurnal Informatika (JIKA) secara khusus menekankan bahwa analisis dan implementasi fitur keamanan pada framework Laravel secara signifikan memperkuat postur keamanan aplikasi web dalam menghadapi ancaman injection dan autentikasi yang lemah. Ancaman nyata seperti brute-force attack, session hijacking, Cross-Site Scripting (XSS), dan SQL Injection telah terdokumentasi secara luas dalam literatur keamanan informasi dan bukan sekadar skenario hipotetis.

Oleh karena itu, proyek ini menempatkan keamanan informasi bukan sebagai fitur tambahan, melainkan sebagai fondasi utama dalam seluruh proses

perancangan dan pembangunan sistem. Pada lapisan autentikasi, sistem menggunakan algoritma hashing Bcrypt dengan 12 rounds iterasi untuk melindungi kata sandi pengguna di basis data. Isnaini et al. (2025) dalam JUSTIN: Jurnal Sistem dan Teknologi Informasi membuktikan bahwa kombinasi Bcrypt hashing password dan algoritma AES secara signifikan meningkatkan keamanan data pengguna pada aplikasi web. Pada lapisan komunikasi, pesan yang dikirimkan melalui fitur chat real-time berbasis WebSocket dienkripsi menggunakan algoritma AES sebelum disimpan ke basis data, sehingga bahkan jika basis data berhasil diakses pihak tidak berwenang, isi pesan tetap tidak dapat terbaca. Pada lapisan otorisasi, sistem menerapkan Role-Based Access Control (RBAC) yang memastikan setiap pengguna hanya dapat mengakses sumber daya sesuai perannya (Mary & Febriyani 2025).

Proyek ini dikerjakan dalam kerangka mata kuliah KOM1315 Keamanan Informasi, Program Studi Ilmu Komputer, IPB University, sebagai penerapan praktis dari konsep kriptografi dan keamanan jaringan yang dipelajari selama Semester Genap 2025/2026.

1.2 Tujuan Proyek

Proyek pengembangan Jatibahagya WebApp memiliki beberapa tujuan spesifik yang terukur, sebagai berikut.

- Membangun platform e-commerce berbasis web yang fungsional sebagai media pemasaran produk furnitur Jatibahagya secara online, mencakup fitur katalog produk, manajemen pesanan, dan pengelolaan inventaris.
- Mengimplementasikan arsitektur keamanan berlapis yang mencakup autentikasi multi-faktor (password hashing Bcrypt + OTP), otorisasi berbasis peran (RBAC), dan enkripsi komunikasi (AES) untuk melindungi aset data pengguna secara komprehensif.
- Mendemonstrasikan dan mengukur dampak implementasi enkripsi terhadap performa sistem melalui pengujian kuantitatif yang membandingkan waktu pemrosesan kondisi plaintext dengan kondisi terenkripsi (analisis overhead).
- Menghasilkan dokumentasi teknis yang lengkap dan sistematis—meliputi proposal, desain sistem, manual administrator, dan log pengujian—sebagai artefak akademis yang dapat dipertanggungjawabkan secara ilmiah sesuai kaidah penulisan IPB University.
- Menyediakan panduan operasional yang praktis bagi administrator sistem dalam mengelola dan memantau fitur-fitur keamanan yang telah diimplementasikan.

1.3 Ruang Lingkup Proyek

Agar pengerjaan proyek ini tetap terfokus dan dapat diselesaikan dalam rentang waktu semester, ruang lingkup proyek dibatasi pada hal-hal berikut.

- Sistem diimplementasikan dalam bentuk aplikasi web yang dapat diakses melalui browser standar (Chrome, Firefox, Edge) tanpa memerlukan instalasi perangkat lunak tambahan dari sisi pengguna.
- Backend sistem dibangun menggunakan framework Laravel 11 (PHP 8.2) dengan basis data relasional MySQL yang terdiri dari 18 tabel yang saling berelasi.
- Frontend menggunakan Blade templating engine bawaan Laravel untuk halaman publik dan pelanggan, serta Filament 3 sebagai framework admin panel.
- Fitur komunikasi real-time menggunakan teknologi WebSocket yang difasilitasi oleh library Reverb dari ekosistem Laravel.
- Implementasi keamanan difokuskan pada tiga domain: (1) pengamanan autentikasi dengan Bcrypt dan OTP, (2) pengamanan komunikasi chat dengan AES, dan (3) pengamanan otorisasi akses dengan RBAC.
- Pengujian dilakukan secara lokal menggunakan lingkungan pengembangan (localhost) dengan spesifikasi perangkat keras yang terdefinisi.

1.4 Manfaat Proyek

Secara praktis, proyek ini memberikan manfaat langsung bagi perusahaan Jatibahagya berupa platform digital yang memungkinkan ekspansi pasar secara online dengan jaminan keamanan data pelanggan yang memadai. Secara akademis, proyek ini menjadi ajang penerapan nyata dari teori keamanan informasi dan kriptografi dalam konteks rekayasa perangkat lunak. Bagi tim pengembang, proyek ini merupakan pengalaman berharga dalam memahami bagaimana keputusan teknis di level kode berdampak langsung pada postur keamanan sebuah sistem secara keseluruhan. Dokumentasi yang dihasilkan juga dapat menjadi referensi bagi pengembang atau peneliti lain yang ingin mengimplementasikan protokol keamanan serupa pada sistem e-commerce berbasis Laravel.

BAB 2 TINJAUAN PUSTAKA

2.1 E-Commerce dan Tantangan Keamanan Informasi di Indonesia

E-commerce atau perdagangan elektronik dapat didefinisikan sebagai proses pembelian, penjualan, atau pertukaran produk, jasa, dan informasi melalui jaringan komputer, termasuk internet (Turban et al. 2018). Dalam perkembangannya, sistem e-commerce tidak hanya berfungsi sebagai media transaksi, tetapi juga sebagai sistem yang mengelola data pelanggan, riwayat pembelian, dan interaksi bisnis yang bersifat sangat sensitif dari perspektif privasi.

Di Indonesia, pertumbuhan e-commerce menunjukkan tren yang konsisten positif. Berdasarkan publikasi Statistik E-Commerce 2023 oleh BPS (2025), nilai transaksi e-commerce nasional terus meningkat dari tahun ke tahun, didorong oleh pertumbuhan penetrasi internet dan meningkatnya kepercayaan masyarakat terhadap transaksi digital. Fenomena ini juga dianalisis oleh Tulungen et al. (2022) dalam Jurnal EMBA yang menegaskan bahwa transformasi digital telah menjadi kebutuhan strategis bagi organisasi dalam berbagai sektor industri, termasuk UMKM manufaktur.

Keamanan informasi dalam konteks e-commerce merujuk pada upaya melindungi data dan sistem dari akses tidak sah, pengungkapan, modifikasi, atau penghancuran yang tidak diinginkan. Tiga pilar utama keamanan informasi yang dikenal dengan akronim CIA Triad—yaitu Confidentiality (kerahasiaan), Integrity (integritas), dan Availability (ketersediaan)—menjadi panduan mendasar dalam merancang sistem yang aman (Stallings 2017). Implementasi protokol keamanan yang tidak memadai dalam sistem e-commerce dapat berakibat pada kebocoran data pribadi pengguna, kerugian finansial, dan kerusakan reputasi yang sulit dipulihkan.

Husain et al. (2024) dalam Jurnal Informatika (JIKA) vol. 8 no. 3 menganalisis dan membuktikan bahwa implementasi fitur keamanan bawaan framework Laravel—termasuk sistem autentikasi, CSRF protection, dan Eloquent ORM—secara signifikan memperkuat postur keamanan aplikasi web terhadap ancaman yang tercantum dalam OWASP Top 10. Temuan ini menjadi landasan ilmiah utama pemilihan Laravel sebagai fondasi teknis proyek ini.

2.2 Kriptografi Simetris: Algoritma AES

Advanced Encryption Standard (AES) merupakan algoritma enkripsi simetris yang ditetapkan oleh National Institute of Standards and Technology (NIST) pada tahun 2001 melalui standar FIPS PUB 197 sebagai pengganti DES yang dianggap tidak lagi aman. AES beroperasi pada blok data berukuran 128 bit

dengan tiga pilihan ukuran kunci: 128 bit, 192 bit, atau 256 bit, di mana jumlah putaran (rounds) bergantung pada ukuran kunci yang dipilih (NIST 2001).

Kekuatan utama AES terletak pada struktur substitusi-permutasi yang membuatnya sangat resisten terhadap serangan kriptanalisis seperti differential cryptanalysis dan linear cryptanalysis. Proses enkripsi AES terdiri dari empat operasi utama yang diulang dalam setiap round, yaitu SubBytes, ShiftRows, MixColumns, dan AddRoundKey (Stallings 2017). Dalam konteks sistem informasi berbasis web, Hermawan et al. (2021) dalam InfoTekJar: Jurnal Nasional Informatika dan Teknologi Jaringan membuktikan bahwa implementasi kombinasi AES dan RSA secara signifikan meningkatkan keamanan data pada sistem informasi. Penelitian yang lebih baru oleh Bimantoro dan Sari (2022) dalam Jurnal Teknik Informatika UIN Jakarta mendemonstrasikan efektivitas AES dalam aplikasi instant messaging berbasis mobile. Temuan-temuan ini memperkuat dasar pemilihan AES sebagai algoritma enkripsi untuk komunikasi chat pada sistem Jatibahagya WebApp.

2.3 Hashing Password dengan Bcrypt

Bcrypt adalah fungsi hashing password yang dirancang oleh Niels Provos dan David Mazières dan dipresentasikan pada konferensi USENIX Annual Technical Conference tahun 1999. Berbeda dengan fungsi hash kriptografi umum seperti MD5 atau SHA-1 yang dirancang untuk beroperasi secepat mungkin, Bcrypt dirancang secara eksplisit untuk berjalan lambat melalui mekanisme cost factor yang dapat dikonfigurasi (Provos & Mazières 1999).

Mekanisme ini sangat penting dalam konteks pengamanan password karena membuat serangan brute-force dan dictionary attack menjadi tidak praktis secara komputasional. Isnaini et al. (2025) dalam JUSTIN: Jurnal Sistem dan Teknologi Informasi vol. 13 no. 1 membuktikan secara empiris bahwa implementasi Bcrypt hashing password dikombinasikan dengan enkripsi AES secara komprehensif mengamankan data sensitif pengguna pada aplikasi web, dengan Bcrypt terbukti lebih unggul secara keamanan dibandingkan MD5 dan SHA-1. Nur (2023) dalam JEAT: Journal of Electrical and Automation Technology juga mendemonstrasikan implementasi Bcrypt untuk keamanan website berbasis One Time Password (OTP), membuktikan efektivitas kombinasi kedua mekanisme ini.

Bcrypt juga secara otomatis menyertakan salt ke dalam proses hashing, yang secara efektif mencegah serangan rainbow table. Dengan cost factor 12 yang digunakan dalam proyek ini, setiap percobaan menebak password membutuhkan waktu komputasi yang signifikan, membuat serangan sistematis menjadi sangat mahal dari segi sumber daya.

2.4 One-Time Password (OTP)

One-Time Password (OTP) adalah mekanisme autentikasi yang menghasilkan kata sandi satu kali pakai yang hanya berlaku untuk satu sesi atau transaksi tertentu. Berbeda dengan password konvensional yang bersifat statis, OTP bersifat dinamis sehingga bahkan jika berhasil dicuri, nilai tersebut tidak dapat digunakan kembali (Menezes et al. 2018).

Implementasi multilayer authentication berbasis Bcrypt dan OTP pada sistem login web diteliti oleh tim peneliti Widya Kartika University yang diterbitkan dalam Jurnal Sistem Cerdas dan Rekayasa (JSCR) vol. 8 no. 1 (2026). Penelitian tersebut membuktikan bahwa sistem yang menggabungkan Bcrypt hashing dengan OTP berbasis SMTP lebih aman secara signifikan dibandingkan sistem autentikasi single-factor. Nur (2023) dalam JEAT juga mendemonstrasikan efektivitas kombinasi Bcrypt dan OTP dalam skenario aplikasi pemerintahan yang diadaptasi dalam proyek ini.

2.5 Kerangka Keamanan AAA

Kerangka AAA merupakan model keamanan yang digunakan secara luas dalam sistem jaringan dan aplikasi untuk mengelola akses pengguna secara komprehensif. Authentication (autentikasi) berkaitan dengan verifikasi identitas pengguna. Authorization (otorisasi) menentukan sumber daya apa yang boleh diakses. Accounting (akuntansi) berkaitan dengan pencatatan dan pemantauan aktivitas pengguna untuk keperluan audit dan deteksi anomali (Stallings 2017).

Tim peneliti Widya Kartika University dalam JSCR (2026) mendemonstrasikan bahwa sistem akademis yang mengintegrasikan MFA, RBAC, dan logging system berhasil memperkuat proteksi terhadap akses tidak sah sekaligus meningkatkan stabilitas sistem. Prinsip yang sama diterapkan dalam sistem Jatibahagya WebApp di mana ketiga komponen AAA diimplementasikan secara terintegrasi.

2.6 Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) adalah metode pengendalian akses yang mengelompokkan pengguna ke dalam peran-peran tertentu dan menetapkan hak akses berdasarkan peran tersebut, bukan berdasarkan identitas individual. Pendekatan ini lebih skalabel dan mudah dikelola dibandingkan manajemen hak akses per individu, khususnya dalam sistem dengan jumlah pengguna yang besar (Ferraiolo et al. 2001).

Di Indonesia, beberapa penelitian relevan mendokumentasikan implementasi RBAC dalam berbagai konteks. Yuricha dan Phan (2023) dalam

MALCOM: Indonesian Journal of Machine Learning and Computer Science vol. 3 no. 2 membuktikan bahwa RBAC dalam sistem supply chain management berbasis cloud secara efektif mencegah akses sumber daya dari pihak yang tidak memiliki otorisasi. Sahyudi dan Susanto (2025) dalam SATESI: Jurnal Sains Teknologi dan Sistem Informasi vol. 5 no. 1 menegaskan bahwa RBAC telah menjadi pendekatan utama dalam meningkatkan keamanan data pada sistem enterprise. Mary dan Febriyani (2025) dalam Jurnal Teknologi dan Sistem Informasi Bisnis vol. 7 no. 3 mendemonstrasikan peningkatan keamanan yang signifikan pada sistem berbasis Laravel melalui implementasi Rate Limiting dan RBAC secara bersamaan.

2.7 Framework Laravel dan Filament 3

Laravel adalah framework PHP open-source yang menyediakan ekosistem lengkap untuk pengembangan aplikasi web modern. Framework ini dipilih dalam proyek Jatibahagya WebApp karena fitur keamanan bawaannya yang komprehensif, termasuk sistem autentikasi bawaan, CSRF protection otomatis, Eloquent ORM yang menerapkan prepared statements untuk mencegah SQL injection, dan manajemen sesi yang aman.

Husain et al. (2024) dalam JIKA vol. 8 no. 3 secara khusus menganalisis dan membuktikan implementasi fitur keamanan pada framework Laravel yang menjadi landasan ilmiah pemilihan Laravel 11. Sinlae et al. (2024) dalam Jurnal Siber Multi Disiplin mendokumentasikan keunggulan Laravel dalam pembangunan aplikasi website berbasis PHP. Filament 3 merupakan framework admin panel untuk Laravel yang menyediakan antarmuka administrasi kaya fitur, termasuk mekanisme otorisasi berbasis peran yang fleksibel dan mudah dikonfigurasi.

2.8 Komunikasi Real-Time Berbasis WebSocket

WebSocket adalah protokol komunikasi dua arah (full-duplex) yang beroperasi di atas koneksi TCP tunggal yang persisten. Berbeda dengan HTTP yang bersifat request-response, WebSocket memungkinkan server mengirimkan data ke client secara proaktif tanpa menunggu permintaan terlebih dahulu. Farizi et al. (2026) dalam Jutisi: Jurnal Ilmiah Teknik Informatika dan Sistem Informasi mendemonstrasikan pengembangan sistem chat berbasis WebSocket dengan enkripsi end-to-end menggunakan AES-GCM dalam lingkungan pendidikan, membuktikan bahwa integrasi WebSocket dengan enkripsi AES menghasilkan sistem komunikasi yang aman sekaligus responsif.

Dalam proyek Jatibahagya WebApp, implementasi WebSocket memanfaatkan Laravel Reverb—first-party WebSocket server yang dirilis sebagai bagian dari ekosistem Laravel 11 pada Maret 2024. Laravel Reverb mengintegrasikan kemampuan real-time WebSocket langsung ke dalam aplikasi

Laravel tanpa memerlukan layanan pihak ketiga, menawarkan performa tinggi dan integrasi seamless dengan fitur broadcasting Laravel yang sudah ada.

BAB 3 PROPOSAL PROYEK

3.1 Latar Belakang Teknis

Perkembangan teknologi informasi dan komunikasi membawa perubahan mendasar dalam pola bisnis modern. Data BPS (2025) menunjukkan bahwa pertumbuhan usaha e-commerce di Indonesia terus meningkat, mencerminkan betapa digitalnya ekosistem bisnis nasional. Tren ini mendorong berbagai pelaku usaha—termasuk UMKM di sektor furnitur—untuk mempertimbangkan digitalisasi operasional bisnis sebagai langkah strategis yang tidak dapat dihindari.

Jatibahagya merupakan perusahaan yang bergerak di bidang produksi dan distribusi furnitur berbahan baku kayu jati pilihan. Sebelum proyek ini dimulai, seluruh proses bisnis perusahaan masih dilakukan secara manual dan tidak terintegrasi. Kondisi ini mengakibatkan beberapa masalah operasional: data pelanggan tersebar di berbagai catatan manual yang rentan hilang atau rusak, proses pemrosesan pesanan yang lambat karena tidak ada sistem terpusat, dan keterbatasan jangkauan pemasaran karena tidak memiliki kehadiran digital yang terstruktur.

Dari sisi teknis, membangun platform e-commerce berarti membangun sistem yang akan mengelola data-data sensitif seperti informasi pribadi pelanggan, data kredensial login, riwayat transaksi, serta percakapan antara pelanggan dan staf. Semua data ini memerlukan perlindungan serius karena kebocoran atau penyalahgunaannya dapat menimbulkan kerugian yang signifikan, baik bagi pelanggan maupun reputasi perusahaan.

Framework Laravel 11 dipilih sebagai fondasi teknis karena beberapa alasan kuat. Pertama, ekosistem keamanan yang matang, termasuk Eloquent ORM yang mencegah SQL injection, CSRF protection, dan session management yang aman (Husain et al. 2024). Kedua, dukungan komunitas yang besar dan dokumentasi yang komprehensif. Ketiga, ekosistem Laravel yang kaya memudahkan integrasi dengan berbagai library yang dibutuhkan, termasuk Filament untuk admin panel dan Reverb untuk WebSocket.

3.2 Identifikasi Masalah

Berdasarkan analisis kebutuhan di awal proyek, beberapa masalah utama dapat diidentifikasi. Pertama, tidak adanya sistem terpusat untuk pengelolaan katalog produk, data pelanggan, dan pemrosesan pesanan mengakibatkan inefisiensi operasional yang signifikan. Kedua, ketiadaan kanal komunikasi digital yang terstruktur antara pelanggan dan staf menyebabkan respons terhadap pertanyaan dan keluhan menjadi lambat dan tidak terdokumentasi.

Ketiga, dan paling relevan dengan fokus mata kuliah ini, adalah ketiadaan proteksi terhadap ancaman keamanan informasi. Sistem baru yang akan dibangun akan menyimpan data sensitif dalam jumlah yang signifikan. Tanpa implementasi mekanisme keamanan yang memadai, sistem tersebut akan sangat rentan terhadap berbagai jenis serangan yang terdokumentasi dalam OWASP Top 10 (OWASP 2021), antara lain: brute-force attack, session hijacking, XSS, SQL Injection, dan penyadapan jaringan (eavesdropping).

3.3 Tujuan dan Target Luaran

Berdasarkan identifikasi masalah, proyek ini menetapkan target luaran yang spesifik dan terukur. Target luaran utama adalah sebuah aplikasi web e-commerce yang fungsional (Jatibahagya WebApp) dengan fitur-fitur inti mencakup katalog produk, manajemen pesanan, dan sistem komunikasi chat real-time.

Target luaran keamanan yang spesifik meliputi: (1) implementasi hashing password Bcrypt dengan cost factor 12; (2) implementasi verifikasi OTP berbasis waktu yang menambahkan lapisan autentikasi kedua; (3) implementasi enkripsi AES pada seluruh pesan yang tersimpan dalam log chat database; (4) implementasi RBAC dengan tiga tingkatan peran (super_admin, staff, customer_support); dan (5) dokumentasi bukti bahwa seluruh skenario kerentanan yang diidentifikasi dalam threat modeling telah berhasil dimitigasi melalui pengujian sistematis menggunakan PHPUnit.

BAB 4 DESAIN SISTEM DAN KEAMANAN

4.1 Arsitektur Sistem

Sistem Jatibahagya WebApp dirancang menggunakan pendekatan Layered Architecture yang memisahkan tanggung jawab setiap komponen sistem secara jelas dan terstruktur. Pendekatan ini dipilih karena pemisahan tanggung jawab (separation of concerns) memudahkan proses debugging dan pemeliharaan kode, serta setiap lapisan dapat diuji secara independen.

Lapisan 1 – Client Layer. Merepresentasikan perangkat pengguna yang mengakses sistem melalui web browser. Komunikasi antara client dan server dilindungi oleh protokol HTTPS yang menggunakan enkripsi TLS untuk memastikan kerahasiaan dan integritas data dalam transmisi.

Lapisan 2 – User Experience Layer. Berisi antarmuka pengguna yang dibangun menggunakan Blade templating engine untuk halaman customer-facing dan Filament 3 untuk panel administrasi.

Lapisan 3 – Middleware/Application Layer. Inti dari sistem yang dibangun di atas framework Laravel 11. Lapisan ini menangani seluruh logika bisnis aplikasi, termasuk routing, controller, service layer, validasi input, manajemen autentikasi (AAA protocol, OTP, Bcrypt), dan manajemen antrian tugas asinkron (queue jobs).

Lapisan 4 – Back-End Resources. Terdiri dari berbagai sumber daya pendukung: MySQL Database dengan 18 tabel relasional, penyimpanan file untuk gambar produk, Mail Server SMTP (Gmail/Mailtrap) untuk pengiriman OTP, dan integrasi dengan IndoRegion API untuk data wilayah administratif Indonesia.

4.2 Analisis Ancaman (Threat Modeling)

Sebelum masuk ke tahap implementasi, tim pengembang terlebih dahulu melakukan analisis ancaman (threat modeling) yang sistematis. Proses ini mengacu pada kerangka kerja STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) dan OWASP Top 10 (2021) untuk mengidentifikasi potensi vektor serangan yang relevan. Hasil analisis ancaman secara lengkap disajikan dalam Tabel 1.

Tabel 1. Perbandingan mekanisme keamanan yang diimplementasikan dan mitigasi ancaman.

Ancaman	Vektor Serangan	Mekanisme Mitigasi	Implementasi Teknis
Brute-Force Attack	Percobaan sistematis semua kemungkinan kombinasi password untuk menebak kredensial pengguna.	Tiga lapisan: (1) Bcrypt cost factor 12; (2) rate limiting 5 percobaan/menit; (3) CAPTCHA pada form login.	password_hash() + Laravel ThrottleMiddleware
SQL Injection	Penyisipan perintah SQL berbahaya ke dalam input pengguna untuk memanipulasi basis data.	Penggunaan Eloquent ORM dengan prepared statements dan parameter binding yang otomatis mencegah penyisipan SQL.	Laravel Eloquent ORM + Query Builder
Session Hijacking	Pencurian token sesi pengguna yang aktif untuk menyamar sebagai pengguna tersebut.	Regenerasi Session ID saat login; penggunaan HTTPS; konfigurasi cookie dengan flag HttpOnly dan Secure.	session()->regenerate() + konfigurasi cookie Laravel
XSS Attack	Penyisipan skrip JavaScript berbahaya ke dalam konten web yang dieksekusi di browser pengguna.	Validasi dan sanitasi input di sisi server; HTML escaping otomatis pada setiap output menggunakan Blade.	{{ \$var }} Blade escaping + Laravel Validator
Eavesdropping Chat	Intersepsi data pesan yang tersimpan di database oleh pihak tidak berwenang.	Enkripsi AES pada seluruh pesan sebelum disimpan ke database; kunci enkripsi disimpan di environment variable.	openssl_encrypt() / Crypt::encryptString() Laravel

Sumber: Hasil analisis ancaman tim Kelompok 6, 2026 (mengacu pada OWASP 2021)

4.3 Desain Basis Data

Basis data sistem Jatibahagya WebApp dibangun menggunakan MySQL dengan desain relasional yang terdiri dari 18 tabel. Desain ini mencerminkan kompleksitas bisnis e-commerce yang mencakup berbagai domain fungsional, mulai dari manajemen pengguna hingga pengelolaan transaksi dan komunikasi.

Dari perspektif keamanan, terdapat beberapa keputusan desain basis data yang secara khusus dilakukan untuk mendukung implementasi protokol keamanan.

Pengamanan kolom password (tabel users). Kolom password tidak pernah menyimpan teks asli (plaintext), melainkan hanya menyimpan hash yang dihasilkan oleh algoritma Bcrypt dengan cost factor 12. Bahkan administrator database tidak dapat mengetahui password asli pengguna dari nilai hash yang tersimpan.

Manajemen OTP (tabel otps). Tabel khusus menyimpan kode OTP sementara dengan kolom expires_at yang menentukan batas waktu kedaluwarsa 30 menit. Setiap OTP yang sudah digunakan atau sudah kedaluwarsa secara otomatis dihapus, mencegah eksploitasi ulang.

Enkripsi pesan (tabel messages). Konten pesan tidak disimpan dalam bentuk plaintext, melainkan dalam bentuk ciphertext yang dihasilkan dari proses enkripsi AES. Kunci enkripsi disimpan secara terpisah dalam environment variable dan tidak pernah di-hardcode di dalam kode sumber.

Implementasi RBAC (kolom role pada tabel users). Kolom role menentukan peran setiap pengguna dalam sistem dan menjadi dasar keputusan otorisasi pada setiap request yang masuk ke aplikasi.

4.4 Protokol Keamanan yang Diimplementasikan

4.4.1 Protokol Autentikasi Pengguna

Protokol autentikasi pengguna pada Jatibahagya WebApp dirancang dalam dua tahap yang saling melengkapi. Tahap pertama adalah verifikasi registrasi awal. Ketika pengguna baru mendaftar, sistem menerima data formulir yang meliputi nama, email, password, dan informasi kontak. Password yang diberikan kemudian di-hash menggunakan Bcrypt dengan cost factor 12 sebelum disimpan ke basis data, sehingga password asli tidak pernah tersimpan dalam bentuk yang dapat dibaca.

Setelah data tersimpan, status akun pengguna baru ditandai dengan `is_verified = false`. Secara bersamaan, sistem menghasilkan kode OTP 6 digit acak, mencatat waktu pembuatannya bersama batas waktu kedaluwarsa 30 menit ke dalam tabel `otps`, lalu mengirimkannya ke alamat email yang didaftarkan. Pengguna harus memasukkan kode OTP yang benar sebelum batas waktu untuk mengaktifkan akunnya. Setelah OTP berhasil diverifikasi, status `is_verified` diubah menjadi `true` dan entri OTP tersebut dihapus dari basis data.

Tahap kedua adalah proses login. Sistem melakukan dua pemeriksaan berurutan: pertama, memverifikasi apakah email terdaftar dan apakah password yang diberikan cocok dengan hash yang tersimpan; kedua, memverifikasi apakah status `is_verified` akun tersebut adalah `true`. Jika kedua kondisi terpenuhi, sistem melakukan regenerasi Session ID untuk mencegah session fixation attack, kemudian mengizinkan akses. Mekanisme rate limiting aktif membatasi percobaan login yang gagal berturut-turut dari IP yang sama.

4.4.2 Protokol Reset Password dengan OTP

Protokol reset password memanfaatkan mekanisme OTP berbasis waktu yang sama dengan verifikasi registrasi. Proses dimulai ketika pengguna memasukkan alamat email pada halaman "Lupa Password". Sistem memverifikasi keberadaan email tersebut dalam basis data. Jika ditemukan, sistem membuat kode OTP baru, mencatatnya dalam tabel `otps`, dan mengirimkannya via email. Pengguna memasukkan OTP yang diterima untuk memverifikasi kepemilikan akun sebelum

diizinkan memasukkan password baru. Password baru kemudian di-hash kembali dengan Bcrypt sebelum disimpan.

4.4.3 Protokol Komunikasi Chat dengan Enkripsi AES

Protokol keamanan pada fitur komunikasi chat adalah yang paling kompleks dan menjadi fokus utama analisis performa dalam proyek ini. Fitur chat menggunakan teknologi WebSocket melalui library Reverb dari ekosistem Laravel untuk memungkinkan komunikasi dua arah secara real-time antara pelanggan dan staf customer support.

Ketika pengguna mengirimkan sebuah pesan, alur prosesnya adalah sebagai berikut. Pertama, pesan yang masuk dari WebSocket diterima oleh handler di sisi server dan dilakukan sanitasi input untuk menghilangkan potensi skrip XSS. Kedua, setelah sanitasi, konten pesan yang sudah bersih dienkripsi menggunakan algoritma AES dengan kunci yang tersimpan di environment variable. Ketiga, ciphertext tersebut yang kemudian disimpan ke dalam tabel messages di basis data MySQL.

Ketika staf customer support perlu menampilkan pesan kepada pengguna yang berwenang, server melakukan proses dekripsi terlebih dahulu sebelum mengirimkan konten ke antarmuka pengguna. Dengan arsitektur seperti ini, bahkan jika seseorang berhasil mendapatkan akses langsung ke basis data, mereka hanya akan melihat deretan ciphertext yang tidak bermakna tanpa kunci dekripsi yang tepat.

4.4.4 Otorisasi Berbasis Peran (RBAC) dengan Filament 3

Implementasi RBAC pada sistem Jatibahagya WebApp memanfaatkan framework admin panel Filament 3. Sistem membagi pengguna ke dalam tiga klaster peran utama dengan hak akses yang berbeda, sebagaimana dirangkum dalam Tabel 2.

Tabel 2. Matriks hak akses RBAC berdasarkan peran pengguna.

Modul / Fitur	super_admin	staff	customer_support	customer	Publik
Dashboard Admin	✓	✓ (terbatas)	✗	✗	✗
Manajemen Pengguna	✓	✗	✗	✗	✗
Katalog Produk	✓	✓	✗	Lihat	Lihat
Pemrosesan Pesanan	✓	✓	✗	Milik sendiri	✗
Fitur Chat Terenkripsi	✓	✗	✓	✓ (sendiri)	✗

Modul / Fitur	super_admin	staff	customer_support	customer	Publik
Log Aktivitas Sistem	✓	X	X	X	X
Pengaturan Sistem	✓	X	X	X	X

Sumber: Desain sistem Kelompok 6, 2026

Pembatasan akses ini diimplementasikan pada tingkat middleware Laravel, yang berarti bahwa request HTTP yang mencoba mengakses sumber daya yang tidak diizinkan akan ditolak di level middleware sebelum sempat menjangkau controller atau logika bisnis.

4.5 Alur Kerja Sistem Secara Keseluruhan

Untuk memberikan gambaran holistik tentang bagaimana seluruh komponen sistem bekerja bersama, berikut ini diuraikan alur kerja end-to-end dari perspektif seorang pelanggan yang berinteraksi dengan sistem Jatibahagya WebApp.

1. Pelanggan baru mengunjungi situs web Jatibahagya melalui browser. Seluruh komunikasi langsung dienkripsi oleh protokol HTTPS/TLS.
2. Pelanggan melakukan registrasi akun. Server menerima data formulir, memvalidasinya, lalu menyimpan hash Bcrypt dari password ke basis data. Status akun ditandai belum terverifikasi dan OTP dikirimkan ke email.
3. Pelanggan memasukkan OTP 6 digit yang diterima via email. Server memvalidasi OTP, mengubah status akun menjadi terverifikasi, lalu menghapus entri OTP dari basis data.
4. Pelanggan login menggunakan email dan password. Sistem memverifikasi hash password dan status akun, lalu membuat sesi yang aman dengan session ID baru.
5. Setelah login, pelanggan menjelajahi katalog produk, menambahkan ke keranjang belanja, dan melakukan pemesanan. Semua interaksi dikontrol oleh middleware yang memastikan hanya pelanggan terautentikasi yang dapat mengakses fitur tersebut.
6. Jika pelanggan menggunakan fitur chat, pesan yang dikirimkan dienkripsi AES di sisi server sebelum disimpan ke basis data. Staf customer support melihat pesan setelah melalui proses dekripsi yang transparan oleh server.

BAB 5 MANUAL PENGGUNAAN FITUR KEAMANAN BAGI ADMINISTRATOR

Bab ini menyajikan panduan operasional yang komprehensif bagi administrator sistem Jatibahagya WebApp dalam mengelola dan memantau fitur-fitur keamanan yang telah diimplementasikan. Panduan ini ditujukan untuk pengguna dengan peran `super_admin` yang memiliki hak akses penuh terhadap seluruh modul sistem.

5.1 Akses Modul Administrasi (Filament)

Panel administrasi Jatibahagya WebApp dibangun menggunakan Filament 3 dan dapat diakses melalui URL khusus yang hanya diketahui oleh personel yang berwenang. Langkah-langkah untuk mengakses panel administrasi adalah sebagai berikut.

7. Buka browser dan navigasi ke URL `/admin` melalui koneksi HTTPS. Akses melalui HTTP biasa akan secara otomatis dialihkan ke HTTPS.
8. Masukkan email dan password yang telah dikonfigurasi dengan peran `super_admin` atau `staff` pada halaman login admin.
9. Sistem melakukan pemeriksaan dua tahap: (a) verifikasi kombinasi email dan password menggunakan pencocokan hash Bcrypt; (b) pemeriksaan apakah akun tersebut memiliki status `is_verified = true` dan peran yang diizinkan untuk mengakses panel Filament.
10. Jika kedua kondisi terpenuhi, administrator diarahkan ke dashboard Filament. Jika tidak, akses ditolak dengan pesan error yang sesuai.

Rekomendasi keamanan operasional: administrator harus selalu menggunakan tombol Logout yang tersedia di panel administrasi saat selesai bekerja, bukan sekadar menutup tab browser. Hal ini memastikan bahwa token sesi dihancurkan secara resmi di sisi server.

5.2 Manajemen Pengguna dan Peran (RBAC)

Manajemen pengguna adalah salah satu tugas administrasi yang paling sering dilakukan. Untuk mengakses modul manajemen pengguna, administrator navigasi ke menu Users pada sidebar panel Filament.

Pada halaman daftar pengguna, administrator dapat melihat seluruh pengguna yang terdaftar beserta informasi peran, status verifikasi, dan tanggal pendaftaran. Kolom role menampilkan salah satu dari tiga nilai: `super_admin`, `staff`, atau `customer_support`, masing-masing dengan indikator warna yang berbeda.

Untuk mengubah peran seorang pengguna, administrator dapat mengklik nama pengguna untuk masuk ke halaman detail, lalu memodifikasi nilai pada field Role sesuai kebutuhan. Perubahan peran akan langsung aktif pada sesi login berikutnya dari pengguna tersebut. Pemberian peran `super_admin` harus dilakukan dengan sangat selektif.

Manajemen status verifikasi akun juga merupakan tanggung jawab administrator. Jika terdapat pengguna yang melaporkan tidak menerima email OTP, administrator dapat secara manual mengubah status `is_verified` setelah melakukan verifikasi identitas pengguna melalui saluran alternatif yang aman.

5.3 Prosedur Autentikasi dan Pengelolaan OTP

Sistem OTP pada *Jatibahagya WebApp* beroperasi secara otomatis tanpa memerlukan intervensi aktif dari administrator dalam kondisi normal. Namun, memahami cara kerjanya penting untuk dapat mendiagnosis masalah yang mungkin timbul.

Ketika seorang pengguna baru mendaftar atau meminta reset password, sistem secara otomatis: (1) menghasilkan kode OTP 6 digit menggunakan fungsi random yang aman secara kriptografis; (2) menyimpan hash OTP tersebut beserta timestamp kedaluwarsa (30 menit dari waktu pembuatan) ke dalam tabel `otps`; dan (3) mengirimkan OTP dalam bentuk plaintext ke email pengguna melalui server SMTP yang dikonfigurasi.

Dari sisi administrasi, jika terdapat keluhan pengguna terkait OTP, administrator dapat memeriksa tabel `otps` untuk memverifikasi apakah entri OTP untuk email tersebut masih ada dan belum kedaluwarsa. Jika entri sudah tidak ada, pengguna perlu meminta OTP baru melalui proses registrasi ulang atau reset password.

5.4 Pemantauan Log Transaksi dan Komunikasi Aman

Komponen Accounting dalam kerangka AAA diwujudkan melalui mekanisme pencatatan log yang terintegrasi. Seluruh perubahan yang terjadi pada data-data sensitif—seperti perubahan harga produk, perubahan status pembayaran pesanan, dan modifikasi data pengguna—dicatat oleh sistem secara otomatis beserta informasi siapa yang melakukan perubahan dan kapan perubahan terjadi.

Administrator dapat memantau log aktivitas ini melalui menu Activity Log yang tersedia di panel Filament. Pemantauan rutin sangat penting untuk mendeteksi anomali yang mungkin mengindikasikan adanya akses tidak sah. Pola yang perlu diwaspadai antara lain: perubahan data di luar jam kerja normal, perubahan masif

pada data produk dalam waktu singkat, atau akses ke data sensitif yang tidak sesuai dengan tanggung jawab peran pengguna yang melakukannya.

Untuk fitur chat, administrator perlu memahami bahwa seluruh pesan yang tersimpan dalam basis data berada dalam format terenkripsi AES. Ketika membuka antarmuka chat melalui panel Filament, server secara otomatis mendekripsi pesan sebelum menampilkannya. Prosedur yang sangat penting: jangan pernah menyalin atau mendistribusikan isi percakapan pelanggan di luar sistem.

5.5 Panduan Keamanan Operasional

Selain prosedur-prosedur teknis yang sudah dijelaskan, terdapat beberapa panduan keamanan operasional yang harus dipatuhi oleh seluruh administrator sistem.

Manajemen Password Administrator. Password untuk akun administrator harus memiliki panjang minimal 12 karakter dan mengombinasikan huruf besar, huruf kecil, angka, dan simbol. Password harus diganti secara berkala setidaknya setiap 90 hari.

Keamanan Perangkat Kerja. Komputer yang digunakan untuk mengakses panel administrasi harus dilindungi dengan password login yang kuat dan harus mengunci layar secara otomatis setelah beberapa menit tidak aktif. Jangan pernah mengakses panel administrasi dari perangkat publik.

Keamanan Jaringan. Sedapat mungkin, akses ke panel administrasi dilakukan hanya melalui jaringan yang terpercaya dan terenkripsi. Hindari mengakses panel administrasi melalui jaringan Wi-Fi publik yang tidak terenkripsi.

Pelaporan Insiden. Jika administrator mencurigai adanya akses tidak sah atau aktivitas mencurigakan pada log, segera laporkan kepada pengelola sistem dan ubah password seluruh akun yang mungkin terdampak.

Audit Periodik. Lakukan audit terhadap daftar pengguna aktif dan peran mereka setidaknya setiap bulan. Nonaktifkan atau hapus akun yang sudah tidak relevan untuk mengurangi permukaan serangan (attack surface).

BAB 6 LOG PENGUJIAN SISTEM

6.1 Lingkungan Pengujian

Seluruh pengujian yang dilaporkan dalam bab ini dilaksanakan pada lingkungan pengembangan lokal (localhost) dengan spesifikasi perangkat keras dan perangkat lunak yang terdefinisi secara konsisten. Penggunaan lingkungan lokal yang terstandardisasi ini penting untuk memastikan bahwa hasil pengujian, khususnya pengukuran kinerja, dapat direproduksi.

Spesifikasi perangkat keras: komputer jinjing MSI dengan prosesor Intel Core i5-12450H generasi ke-12 berkecepatan 2.00 GHz, RAM sebesar 16.0 GB, dan GPU NVIDIA GeForce RTX 2050 (VRAM 4 GB), berjalan pada sistem operasi Windows 11 64-bit. Spesifikasi perangkat lunak: XAMPP dengan PHP versi 8.2, MySQL versi 8.0, dan framework Laravel versi 11. Pengujian fungsional dan pengujian performa dilakukan menggunakan PHPUnit sebagai test runner yang terintegrasi dengan Laravel.

Pengujian dilaksanakan dalam dua kategori: (1) pengujian fungsional dan keamanan yang bersifat kualitatif, dan (2) pengujian performa yang bersifat kuantitatif. Seluruh kode pengujian tersedia dalam direktori 05_Testing/ pada repositori proyek di GitHub (github.com/Akbar3776/KOM1315_SmtGenap26_Kelompok6_E-CommerceJatibahagya).

6.2 Skenario Pengujian Fungsional dan Keamanan

Pengujian fungsional dan keamanan dilakukan menggunakan test suite PHPUnit. Setiap skenario pengujian dirancang untuk memverifikasi satu kondisi spesifik dari sistem, mencakup alur normal (happy path) dan kondisi-kondisi batas (edge cases) yang relevan dari perspektif keamanan. Ringkasan seluruh skenario pengujian disajikan dalam Tabel 3.

Tabel 3. Ringkasan skenario pengujian fungsional dan keamanan sistem *Jatibahagya WebApp*.

ID	Modul	Tipe Uji	Deskripsi Skenario	Hasil yang Diharapkan	Status
SU-01	Registrasi	Happy Path	Input data pengguna baru yang valid (nama, email baru, password, telepon). Submit formulir registrasi.	User dibuat, password ter-hash Bcrypt, is_verified=false, OTP dikirim ke email.	✓ LULUS

ID	Modul	Tipe Uji	Deskripsi Skenario	Hasil yang Diharapkan	Status
SU-02	Registrasi	Negative Test	Input email yang sudah terdaftar pada akun lain.	Validasi gagal, pesan error 'Email sudah digunakan' ditampilkan.	✓ LULUS
LI-01	Login	Happy Path	Input email & password benar untuk akun dengan is_verified=true.	Login berhasil, Session ID diregenerasi, diarahkan ke halaman /orders.	✓ LULUS
LI-02	Login	Edge Case	Input email & password benar untuk akun dengan is_verified=false.	Login ditolak, pesan 'Akun belum diverifikasi' ditampilkan.	✓ LULUS
LI-03	Login	Security Test	Brute-force: 6 percobaan login gagal berurutan dari IP sama.	Request ke-6 ditolak oleh rate limiting (HTTP 429 Too Many Requests).	✓ LULUS
OTP-01	Verifikasi OTP	Happy Path	Input OTP 6 digit yang benar dan masih berlaku.	Akun terverifikasi, is_verified=true, entri OTP dihapus dari DB.	✓ LULUS
OTP-02	Verifikasi OTP	Negative Test	Input OTP yang salah.	Validasi gagal, akun tetap belum terverifikasi.	✓ LULUS
OTP-03	Verifikasi OTP	Edge Case	Input OTP yang benar namun sudah melewati batas waktu 30 menit.	Validasi gagal, pesan 'OTP sudah kadaluarsa' ditampilkan.	✓ LULUS
RP-04	Reset Password	Happy Path	Input OTP reset valid, password baru dan konfirmasi sama.	Password diperbarui (hash Bcrypt baru), diarahkan ke halaman login.	✓ LULUS
ADM-LG-01	Login Admin	Happy Path	Email & password admin valid dengan peran super_admin.	Admin berhasil login, diarahkan ke dashboard Filament.	✓ LULUS
ADM-LG-05	Isolasi Akses	Security Test	Akun dengan peran customer mencoba mengakses URL /admin.	Akses ditolak oleh middleware (403 Forbidden), diarahkan kembali.	✓ LULUS
SEC-01	XSS Protection	Security Test	Input skrip JavaScript berbahaya pada field nama pengguna.	Input di-escape oleh Blade, skrip tidak dieksekusi saat ditampilkan.	✓ LULUS
CHAT-01	Enkripsi Chat	Security Test	Pesan dikirim via WebSocket, isi kolom content di DB diperiksa langsung.	Isi kolom content adalah ciphertext (tidak terbaca), bukan plaintext.	✓ LULUS

Sumber: Hasil pengujian tim Kelompok 6, 2026

6.3 Pengujian Performa: Plaintext vs Enkripsi AES

Pengujian performa merupakan aspek paling krusial dan inovatif dari proyek ini dari perspektif akademis. Tujuan pengujian ini adalah mengkuantifikasi dampak nyata implementasi enkripsi AES terhadap kinerja sistem, diukur melalui overhead—yaitu selisih waktu pemrosesan antara kondisi tanpa enkripsi (plaintext) dan kondisi terenkripsi (AES).

Pengujian dilakukan menggunakan test case AuthEncryptionPerformanceTest.php yang terdapat dalam direktori 03_Source_Code/backend/tests/Feature/Auth/ pada repositori proyek. Test ini dapat dieksekusi menggunakan perintah berikut.

```
php artisan test --filter=AuthEncryptionPerformanceTest
```

Setiap kondisi diuji menggunakan tiga variasi ukuran data: Kueri 1 dengan data pendek (kurang dari 50 karakter), Kueri 2 dengan data sedang (50 hingga 200 karakter), dan Kueri 3 dengan data panjang (lebih dari 200 karakter). Setiap kueri dieksekusi sebanyak 100 kali dan diambil nilai rata-ratanya untuk meminimalkan bias pengukuran. Rumus yang digunakan untuk menghitung persentase overhead adalah sebagai berikut.

$$\text{Overhead (\%)} = ((T_{\text{enkripsi}} - T_{\text{plaintext}}) / T_{\text{plaintext}}) \times 100\%$$

Hasil pengujian performa yang diperoleh disajikan secara lengkap dalam Tabel 4.

Tabel 4. Perbandingan waktu rata-rata pemrosesan: plaintext vs enkripsi AES.

Skenario Uji	Ukuran Data	Waktu Rata-rata Plaintext (ms)	Waktu Rata-rata Enkripsi AES (ms)	Overhead (%)
Kueri 1	< 50 karakter	0.942	0.968	2.73%
Kueri 2	50 – 200 karakter	0.938	0.986	5.16%
Kueri 3	> 200 karakter	1.049	1.068	1.87%
Rata-rata Keseluruhan	Semua ukuran	0.976	1.007	3.25%

Sumber: Hasil uji AuthEncryptionPerformanceTest.php, Kelompok 6, 2026

Tabel 5. Analisis overhead enkripsi dan implikasinya terhadap pengalaman pengguna real-time.

Parameter	Nilai	Interpretasi
Overhead tertinggi	5.16% (Kueri 2)	Setara 0.048 ms dalam nilai absolut. Tidak signifikan secara perceptual bagi pengguna.
Overhead terendah	1.87% (Kueri 3)	Untuk pesan panjang, operasi konstan enkripsi relatif lebih kecil dari total waktu pemrosesan.
Latensi rata-rata (terenkripsi)	~1.007 ms	Jauh di bawah threshold real-time (100 ms). Tergolong 'hampir instan' menurut standar industri.
Latensi rata-rata (plaintext)	~0.976 ms	Baseline referensi tanpa beban enkripsi untuk perbandingan.
Ambang batas 'real-time'	< 100 ms	Standar industri untuk aplikasi real-time. Sistem melampaui standar ini dengan sangat baik.

Sumber: Kelompok 6, 2026 (mengacu pada standar latensi WebRTC dan WebSocket)

6.4 Analisis Hasil Pengujian

Hasil pengujian yang tersaji dalam Tabel 3, 4, dan 5 memberikan sejumlah temuan penting yang perlu dianalisis secara mendalam.

Terkait pengujian fungsional dan keamanan, seluruh 13 skenario yang diuji—termasuk tiga skenario bertipe Security Test—berhasil lulus dengan status LULUS. Ini merupakan bukti empiris yang kuat bahwa seluruh mekanisme keamanan yang diimplementasikan berfungsi sesuai spesifikasi. Yang paling signifikan dari perspektif keamanan adalah keberhasilan skenario ADM-LG-05, yang membuktikan bahwa isolasi akses administratif benar-benar bekerja: pengguna dengan peran customer tidak dapat memaksa masuk ke dashboard admin. Skenario CHAT-01 juga membuktikan bahwa enkripsi AES pada pesan chat berfungsi dengan benar—isi pesan yang tersimpan di database berupa ciphertext yang tidak dapat dibaca secara langsung. Temuan ini konsisten dengan hasil penelitian Yuricha dan Phan (2023) dalam MALCOM mengenai efektivitas RBAC dalam mengontrol akses pada sistem berbasis web.

Terkait pengujian performa enkripsi AES, data pada Tabel 4 memberikan gambaran yang sangat menarik. Overhead tertinggi tercatat pada Kueri 2 (ukuran data sedang) sebesar 5.16%, yang dalam nilai absolut hanya setara dengan selisih 0.048 ms. Overhead terendah justru terjadi pada Kueri 3 (ukuran data panjang) sebesar 1.87%, yang menunjukkan bahwa untuk pesan yang lebih panjang, operasi-operasi konstan dalam proses enkripsi relatif lebih kecil dibandingkan total waktu pemrosesan keseluruhan.

Yang paling penting untuk dicatat adalah bahwa ketiga skenario pengujian menghasilkan latensi yang konsisten di kisaran 1 milidetik, baik dalam kondisi plaintext maupun terenkripsi. Nilai ini jauh di bawah ambang batas yang diakui secara umum untuk aplikasi real-time. Temuan ini memperkuat argumen yang

dikemukakan oleh Hermawan et al. (2021) dalam InfoTekJar bahwa enkripsi berbasis AES efektif diimplementasikan dalam sistem informasi tanpa mengorbankan performa secara berarti.

Temuan ini memiliki implikasi praktis yang sangat penting: implementasi enkripsi AES pada sistem komunikasi chat real-time Jatibahagya WebApp memberikan lapisan perlindungan keamanan yang sangat berarti tanpa mengorbankan pengalaman pengguna. Dengan kata lain, trade-off antara keamanan dan performa yang sering menjadi pertimbangan dalam pengembangan sistem berhasil diselesaikan dengan sangat baik dalam proyek ini. Hal ini sejalan dengan temuan Farizi et al. (2026) dalam Jutisi yang juga membuktikan bahwa sistem chat berbasis WebSocket dengan enkripsi AES dapat mencapai tingkat fungsionalitas dan keamanan yang tinggi secara bersamaan.

Satu catatan metodologis yang perlu disampaikan adalah bahwa pengujian ini dilakukan pada lingkungan pengembangan lokal, bukan lingkungan produksi. Dalam kondisi produksi dengan beban pengguna yang nyata (concurrent users), nilai overhead mungkin akan sedikit berbeda karena adanya kompetisi sumber daya CPU dan memori. Namun, mengingat overhead yang terekam bahkan dalam kondisi tanpa beban sudah sangat kecil, dapat diantisipasi bahwa dampaknya pada lingkungan produksi akan tetap dalam batas yang sangat dapat diterima.

BAB 7 PENUTUP

7.1 Kesimpulan

Berdasarkan seluruh rangkaian proses pengerjaan, implementasi, dan pengujian yang telah dilakukan, beberapa kesimpulan utama dapat ditarik sebagai berikut.

Pertama, proyek ini berhasil merancang dan mengimplementasikan sistem e-commerce Jatibahagya WebApp yang fungsional dengan arsitektur keamanan berlapis yang komprehensif. Sistem dibangun di atas fondasi framework Laravel 11 dengan memanfaatkan berbagai tools dan library yang sudah teruji industri untuk mendukung implementasi protokol keamanan yang solid.

Kedua, mekanisme autentikasi berlapis yang terdiri dari kombinasi hashing password Bcrypt (12 rounds) dan verifikasi OTP berbasis waktu terbukti efektif dalam mencegah berbagai bentuk serangan pada tahap autentikasi. Bcrypt memastikan bahwa bahkan dalam skenario terburuk di mana basis data berhasil diakses secara tidak sah, data password pengguna tetap terlindungi. Temuan ini konsisten dengan hasil penelitian Isnaini et al. (2025) dalam JUSTIN yang membuktikan efektivitas kombinasi Bcrypt dan AES dalam pengamanan data pengguna.

Ketiga, implementasi RBAC dengan tiga tingkatan peran (super_admin, staff, customer_support) yang didukung oleh isolasi middleware yang ketat terbukti berhasil mencegah eskalasi hak akses yang tidak sah. Skenario ADM-LG-05 yang berhasil lulus merupakan bukti empiris bahwa pengguna biasa tidak dapat memaksa masuk ke area administrasi sistem, sejalan dengan temuan Yuricha dan Phan (2023) dalam MALCOM mengenai efektivitas RBAC dalam mengontrol akses pada sistem berbasis web.

Keempat, dan ini merupakan temuan paling signifikan dari perspektif akademis, implementasi enkripsi AES pada komunikasi chat real-time menghasilkan overhead latensi yang sangat minimal (maksimum 5.16%, setara 0.048 ms dalam nilai absolut) dan sama sekali tidak berdampak pada keterjangkauan pengalaman pengguna real-time. Latensi rata-rata yang konsisten di kisaran 1 ms membuktikan bahwa implementasi kriptografi yang tepat tidak harus mengorbankan performa sistem secara berarti. Temuan ini memperkuat argumen yang dikemukakan oleh Hermawan et al. (2021) dalam InfoTekJar bahwa enkripsi berbasis AES efektif diimplementasikan dalam sistem informasi tanpa mengorbankan performa.

Kelima, seluruh 13 skenario pengujian fungsional dan keamanan yang telah didefinisikan berhasil lulus, memberikan jaminan bahwa sistem berfungsi sesuai spesifikasi dan mekanisme mitigasi ancaman yang didesain dalam fase threat modeling berhasil diimplementasikan dengan benar.

7.2 Saran Pengembangan

Meskipun proyek ini telah berhasil mencapai seluruh tujuan yang ditetapkan, terdapat beberapa area yang dapat dikembangkan lebih lanjut dalam iterasi berikutnya.

Implementasi Two-Factor Authentication (2FA). Selain OTP yang saat ini digunakan untuk verifikasi akun dan reset password, implementasi 2FA berbasis aplikasi autentikator (seperti Google Authenticator atau Authy) untuk proses login sehari-hari akan memberikan lapisan keamanan tambahan, terutama untuk akun-akun dengan hak akses tinggi.

Pengujian Penetrasi Eksternal (Pentest). Untuk validasi keamanan yang lebih komprehensif, sangat disarankan melibatkan pihak ketiga yang independen untuk melakukan pengujian penetrasi terhadap sistem, yang dapat mengungkap celah keamanan yang mungkin tidak terdeteksi dalam pengujian internal.

Implementasi Enkripsi End-to-End (E2EE). Enkripsi AES yang diimplementasikan saat ini dilakukan di sisi server. Untuk meningkatkan kerahasiaan komunikasi ke tingkat yang lebih tinggi, dapat dipertimbangkan implementasi E2EE di mana proses enkripsi dan dekripsi terjadi di sisi klien, sehingga server pun tidak pernah memiliki akses ke plaintext pesan.

Monitoring dan Alerting Real-Time. Implementasi sistem pemantauan keamanan real-time yang dapat mendeteksi anomali dan mengirimkan peringatan kepada administrator ketika terjadi pola aktivitas yang mencurigakan.

Pengujian Performa pada Lingkungan Produksi. Memperluas pengujian performa ke lingkungan yang lebih menyerupai kondisi produksi dengan mensimulasikan beban pengguna yang nyata menggunakan tools load testing seperti Apache JMeter atau Locust.

DAFTAR PUSTAKA

- [BPS] Badan Pusat Statistik. 2025. Statistik E-Commerce 2023. Jakarta (ID): Badan Pusat Statistik Indonesia. [diakses 2026 Mei 15]. Tersedia pada: <https://www.bps.go.id/id/publication/2025/01/30/d52af11843aee401403ecfa6/statistik-e-commerce-2023.html>
- Bimantoro Y, Sari RTK. 2022. Enkripsi Data Menggunakan RSA & AES pada Aplikasi Instant Messaging Berbasis Mobile. *Jurnal Teknik Informatika*. 15(2). DOI:10.15408/jti.v14i2.23469. [diakses 2026 Apr 10]. Tersedia pada: <https://journal.uinjkt.ac.id/index.php/ti/article/view/23469>
- Farizi A, Yunus A, Kurniawan A, Firmansyah Y, Fadilah M, Ramadhan N. 2026. Rancangan EduChat Berbasis WebSockets dan E2EE di Institut Pendidikan Indonesia Garut. *Jutisi: Jurnal Ilmiah Teknik Informatika dan Sistem Informasi*. [diakses 2026 Mei 20]. Tersedia pada: <https://ojs.stmik-banjarbaru.ac.id/index.php/jutisi/article/view/3600>
- Ferraiolo DF, Sandhu R, Gavrila S, Kuhn DR, Chandramouli R. 2001. Proposed NIST Standard for Role-Based Access Control. *ACM Transactions on Information and System Security*. 4(3):224–274. DOI:10.1145/501978.501980
- Hermawan L, Pradana HA, Sylfania DY, Juniawan FP. 2021. Implementasi Enkripsi Data Menggunakan Kombinasi AES dan RSA. *InfoTekJar: Jurnal Nasional Informatika dan Teknologi Jaringan*. 6(1):1–5. [diakses 2026 Apr 5]. Tersedia pada: <https://jurnal.uisu.ac.id/index.php/infotekjar/article/view/3585>
- Husain SM, Azhari L, Aksani ML, Saputra SA. 2024. Analisis dan Implementasi Fitur Keamanan Aplikasi pada Framework Laravel. *JIKA (Jurnal Informatika)*. 8(3):281–290. DOI:10.31000/jika.v8i3.11198. [diakses 2026 Apr 12]. Tersedia pada: <https://jurnal.umt.ac.id/index.php/jika/article/view/11198>
- Inzaghi TM, Romadhon MS, Akbar MF. 2026. Repositori Proyek KOM1315 Keamanan Informasi – E-Commerce Jatibahagya Kelompok 6. Bogor (ID): IPB University. Tersedia pada: https://github.com/Akbar3776/KOM1315_SmtGenap26_Kelompok6_E-CommerceJatibahagya
- Isnaini K, Nur D, Suhartono D, Thoriq M, Qothrunnada A. 2025. Implementasi Pengamanan Data Menggunakan Teknik Bcrypt Hashing Password dan Algoritma Advanced Encryption Standard (AES). *JUSTIN: Jurnal Sistem dan Teknologi Informasi*. 13(1):101–108. DOI:10.26418/justin.v13i1.84997. [diakses 2026 Apr 8]. Tersedia pada: <https://jurnal.untan.ac.id/index.php/justin/article/view/84997>
- [Kemkominfo] Kementerian Komunikasi dan Informatika RI. 2020. Peta Jalan Transformasi Digital Indonesia 2021–2024. Jakarta (ID): Kementerian Komunikasi dan Informatika.

- Mary T, Febriyani N. 2025. Peningkatan Keamanan Sistem Informasi Berbasis Laravel 12 dengan Rate Limiting dan Role-Based Access Control (RBAC). *Jurnal Teknologi dan Sistem Informasi Bisnis*. 7(3):473–481. DOI:10.47233/jteksis.v7i3.1976. [diakses 2026 Apr 20]. Tersedia pada: <https://jurnal.unived.ac.id/index.php/jteksis/article/view/1976>
- Menezes AJ, Van Oorschot PC, Vanstone SA. 2018. *Handbook of Applied Cryptography*. 5th ed. Boca Raton (US): CRC Press.
- [NIST] National Institute of Standards and Technology. 2001. *Advanced Encryption Standard (AES) [FIPS PUB 197]*. Gaithersburg (US): National Institute of Standards and Technology. Tersedia pada: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.197.pdf>
- Nur J. 2023. Implementation of Bcrypt Algorithm for Sipapeda Website Security at Bappeda Office, Buton Regency with One Time Password Method. *JEAT: Journal of Electrical and Automation Technology*. 2(2):90–96. [diakses 2026 Apr 3]. Tersedia pada: <https://jurnal.pnj.ac.id/index.php/jeat/article/view/6200>
- [OWASP] OWASP Foundation. 2021. *OWASP Top Ten 2021*. [Internet]. [diakses 2026 Mei 10]. Tersedia pada: <https://owasp.org/www-project-top-ten/>
- Provos N, Mazières D. 1999. A Future-Adaptable Password Scheme. In: *Proceedings of the USENIX Annual Technical Conference; 1999 Jun 6–11; Monterey, California*. Berkeley (US): USENIX Association. hlm 32–39.
- Sahyudi M, Susanto ER. 2025. Analisis Implementasi Sistem Keamanan Basis Data Berbasis Role-Based Access Control (RBAC) pada Aplikasi Enterprise Resource Planning. *SATESI: Jurnal Sains Teknologi dan Sistem Informasi*. 5(1):105–116. DOI:10.54259/satesi.v5i1.3997. [diakses 2026 Apr 25]. Tersedia pada: <https://ejournal.upbatam.ac.id/index.php/satesi/article/view/3997>
- Sinlae F, Irwanda E, Maulana Z, Syahputra VE. 2024. Penggunaan Framework Laravel dalam Membangun Aplikasi Website Berbasis PHP. *Jurnal Siber Multi Disiplin (JSMD)*. 2(2). DOI:10.38035/jsmd.v2i2. [diakses 2026 Apr 18]. Tersedia pada: <https://jurnal.uma.ac.id/index.php/jsmd>
- Stallings W. 2017. *Cryptography and Network Security: Principles and Practice*. Ed ke-7. Boston (US): Pearson.
- Tim Peneliti Widya Kartika University. 2026. Implementasi Cryptography Based Multilayer Authentication pada Sistem Login Berbasis Web Menggunakan Bcrypt Hashing dan One Time Password (OTP). *Jurnal Sistem Cerdas dan Rekayasa (JSCR)*. 8(1). [diakses 2026 Mei 25]. Tersedia pada: <https://ojs.widyakartika.ac.id/index.php/jscr/article/view/946>
- Tulungen EE, Saerang DP, Maramis JB. 2022. Transformasi Digital: Peran Kepemimpinan Digital. *Jurnal EMBA: Jurnal Riset Ekonomi, Manajemen, Bisnis dan Akuntansi*. 10(2):455–465. DOI:10.35794/emba.v10i2.41007

- Turban E, Whiteside J, King D, Outland J. 2018. Introduction to Electronic Commerce and Social Commerce. 4th ed. Cham (CH): Springer.
- Yuricha Y, Phan IK. 2023. Penerapan Role Based Access Control dalam Sistem Supply Chain Management Berbasis Cloud. MALCOM: Indonesian Journal of Machine Learning and Computer Science. 3(2):339–348. DOI:10.57152/malcom.v3i2.1259. [diakses 2026 Apr 22]. Tersedia pada: <https://journal.irpi.or.id/index.php/malcom/article/view/1259>

Laporan ini disusun sebagai pemenuhan tugas akhir mata kuliah KOM1315 Keamanan Informasi Program Studi Ilmu Komputer, IPB University | Semester Genap 2025/2026